



2026 上海开源软件应用创新大赛

AI Aegis (灵盾)

面向企业自研 Agent 的开源运行时安全治理与可观测平台

五段式安全管线	Manifest 最小权限	会话级漂移检测	可验证审计
---------	---------------	---------	-------

参赛赛道

开源 AI 工具赛道 · AI 编程、调试与可观测工具 · 自主选题

项目负责人：万翔浩 | 提交版本：v1.0 | 日期：2026年9月

让每一次 Agent 工具调用都可约束、可解释、可追溯、可验证。

01

项目摘要

从 “模型是否安全” 转向 “Agent 行为是否越界”

AI Aegis（灵盾）是一套面向 AI 编程 Agent 与企业自研 Agent 的开源运行时安全治理平台。它位于 LLM、Agent 与工具执行之间，在文件写入、Shell 命令、网络访问、MCP 调用等动作真正发生前进行策略判断，并把每次决定记录为可复核的证据。

PreTool

执行前控制

风险动作发生前介入

5 STAGES

分层证据决策

规则 + 语义证据 + 状态机

LOCAL

本地优先

无 API Key 也可运行

核心价值

- 面向开发者：正常任务尽量无感放行，高风险动作给出确认或阻断，并展示原因。
- 面向企业管理员：用 Manifest 定义 Agent 可以做什么、能影响多大范围，并在后台集中查看证据。
- 面向高校与研究团队：提供开放的 Agent 攻防实验框架、可复现 Benchmark 与消融测试能力。
- 面向安全运营人员：将 Prompt、模型响应、工具调用和策略版本串成同一条因果链。

产品边界

社区版当前交付以单机/轻量服务器部署、运行时管控、审计与安全运营原型为主。多租户 SSO/RBAC、高可用集群、组织级审批链与大规模策略灰度属于企业产品化路线，不在本次材料中冒充已完成能力。

项目背景与问题定义

Agent 的风险不只存在于一句 Prompt，而存在于完整的意图与行为链

传统内容安全通常回答“这句话是否有害”，系统安全通常回答“这个进程是否调用了危险接口”。但 Agent 会把自然语言转化为连续工具动作：读取文件、运行命令、访问网络、调用企业系统。许多单步动作本身合法，组合起来却可能形成权限爬升、数据外传或破坏性操作。

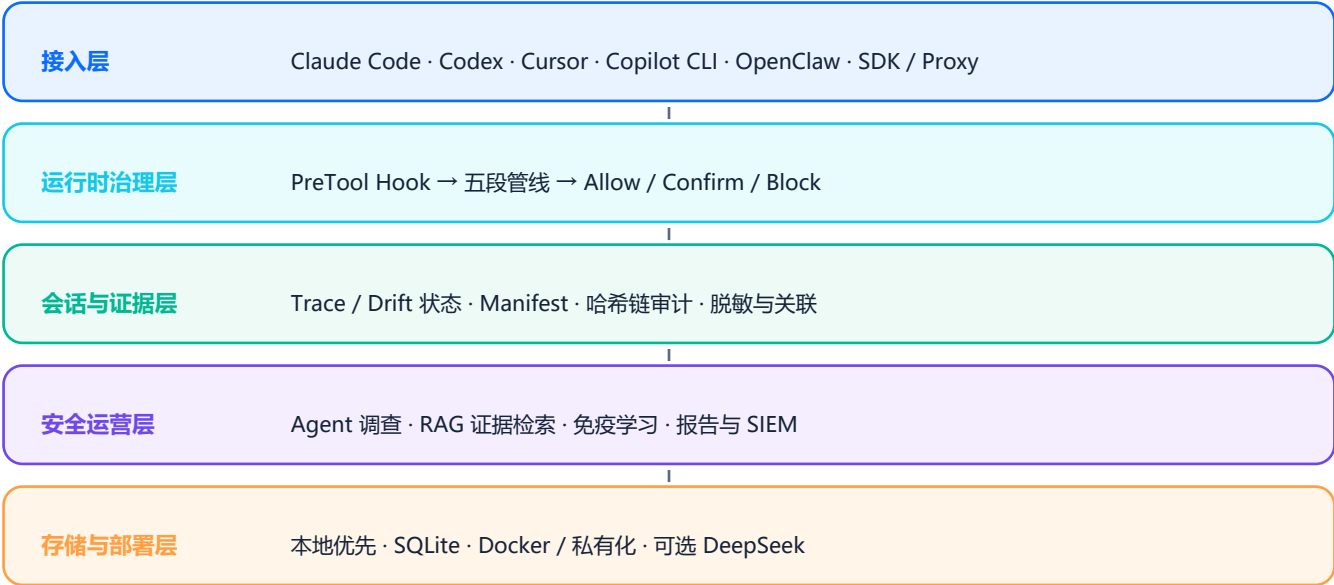
真实痛点	传统方案的缺口	AI Aegis 的处理方式
单轮正常，多轮逐步越界	只检查当前工具调用，无法看见会话漂移	以 traceId 重建会话，Drift 状态机累积证据
工具调用字段结构化，但意图是自然语言	纯正则无法理解语义，纯 LLM 又不稳定	规则处理确定性问题，LLM 只提取闭集标签
企业 Agent 权限边界不清	只有全局允许/禁止，缺少任务范围	Manifest 声明能力、目录、网络和工具范围
阻断后无法解释与追责	只有告警，没有完整因果证据	哈希链审计、会话回放、策略版本关联
安全过严影响开发	默认全拒绝导致高摩擦	Allow / Confirm / Block 分级处置与授权复用

目标

构建一套不依赖单点大模型 Judge、能在真实开发工作流中运行、能够被测试和审计的 Agent 安全治理工具：既阻止高确定性危险行为，也对模糊语义风险给出可解释的分层证据。

总体技术架构

插件主动绑定上下文，安全决策与业务 Agent 解耦



层级	职责	主要实现
接入层	捕获 Prompt、响应与工具调用	原生 Hook、SDK、HTTP Proxy、MCP 适配器
治理层	执行前判断与分级处置	Boundary / Capability / Radius / Drift / Friction
证据层	关联会话、保存状态与证明	traceld、Manifest、SQLite、SHA-256 哈希链
运营层	调查、检索、报告、学习	受控 LangGraph、混合 RAG、免疫生命周期、SIEM
部署层	满足本地与私有化环境	Windows/Linux、Docker、本地模型与可选云模型

双流观测

系统区分意图流（用户输入、模型输入输出、工具结果中的注入信息）和行为流（工具名、参数、目标路径、网络目的地及执行结果）。两条流通过 traceld、sessionId、turnIndex 和 parentSpanId 关联，避免只看到 HTTP 报文或孤立工具调用。

五段式 PreTool 决策管线

确定性检查优先，模糊语义按需调用模型，最终裁决由代码完成



规则处理确定性风险 · LLM 仅提取离散语义证据 · 状态机与决策表负责最终裁决

阶段	主要输入	实现方式	输出及作用
Boundary	命令、路径、文本与编码特征	硬规则为主：归一化、零宽/全角、高危 Shell、敏感路径	命中明确红线时直接产生 Critical 信号
Capability	tool_name、Manifest 能力集合	结构化集合匹配；自然语言隐式能力可选语义解析	识别未声明能力，通常进入 Confirm
Radius	路径、网络目标、影响对象	规则解析项目/本机/用户/系统/外网范围	判断任务作用域是否扩大
Drift	历史信号、重试、语义标签	确定性状态机累计分数；LLM 只输出布尔/枚举标签	捕获主题偏移、权限试探和请求升级
Friction	原始检测 + 前四层证据	固定权重、阈值与决策表	输出 Allow / Confirm / Block

设计原则

性能	确定性	可解释	可替换
大部分检查毫秒级完成	相同证据得到相同裁决	每个信号可追溯到来源	可替换 DeepSeek/本地模型而不改状态机

核心产品能力

不是聊天壳，而是贯穿安装前、运行时与事后审计的安全工具

能力域	已经实现的能力	用户价值
运行时安全	五段管线、规则引擎、Guardian 本地分类器、Allow/Confirm/Block	危险工具调用在执行前被控制
权限治理	能力 Manifest、目录与影响范围、JIT 临时授权、无人值守升级策略	从“全能 Agent”转向最小权限
会话可观测	Trace 时间线、Drift 曲线、Agent Map、调用与成本关联	快速回答谁在何时因何规则被拦截
审计取证	SHA-256 哈希链、脱敏预览、链完整性验证、报告导出	降低日志被静默修改后的取证风险
安全运营 Agent	受控工作流、只读工具、证据 RAG、人工审批策略提案	自然语言调查，但模型不能自行改策略
免疫学习	Candidate→Shadow→Active→Decaying→Retired	从历史攻击序列学习，同时限制自动误杀
证据处理	PDF/DOCX/表格/日志/截图 OCR、去重、限额与脱敏	把制度、告警和现场材料纳入调查
生态接入	Claude Code、Codex、Cursor、Copilot CLI、OpenClaw、SDK/Proxy	覆盖主流 AI 编程和自研 Agent

可选模型，而非启动前提

不配置 DeepSeek API Key 时，规则、Guardian 本地模型、Manifest、审计和前端均可运行；配置模型后，系统按需增加主题偏移、权限试探、请求升级、明确有害目标等语义证据。模型不可直接返回最终风险分数，也不能绕过 Friction 决策表。

典型应用场景

同一治理内核服务开发者、高校实验室和企业管理员

场景	典型风险	演示流程	交付价值
AI 编程助手	误删项目、越权读文件、泄露密钥、危险 Git/Shell	正常读取放行 → 越界写入确认 → 高危命令阻断 → Trace 回放	减少开发干扰并保留责任链
企业自研 Agent	工具权限过宽、跨系统访问、网络外传	生成 Manifest → 绑定 Agent → 运行策略 → 管理员复核与导出	形成可审计的 Agent 上线门槛
MCP 生态治理	恶意工具描述、工具结果注入、未授权能力	扫描工具/Skill → 运行时检查 → MCP 策略与日志	降低插件和工具供应链风险
高校攻防实验	中文多轮越狱、链式诱导、权限爬升	回放数据集 → 观察五层信号 → 调阈值 → 比较召回与误报	可复现实验与教学框架
安全运营调查	告警分散、证据无关联、报告制作慢	上传证据 → RAG 检索 → 会话调查 → 人工审批 → 导出报告	提升调查效率并控制 Agent 权限

推荐现场演示闭环

- 01 导入一个 AI 编程 Agent，并加载推荐开发 Manifest。
- 02 执行正常的 README 读取与项目内修改，展示无干扰 Allow。
- 03 触发项目外写入、敏感信息外传和破坏性命令，展示 Confirm/Block。
- 04 重复进行权限试探，展示 Drift 分数与会话证据累积。
- 05 在后台回放完整 Trace，验证哈希链并导出审计报告。

关键创新点

创新不在“多调用几次 LLM”，而在安全决策的工程解耦与证据闭环

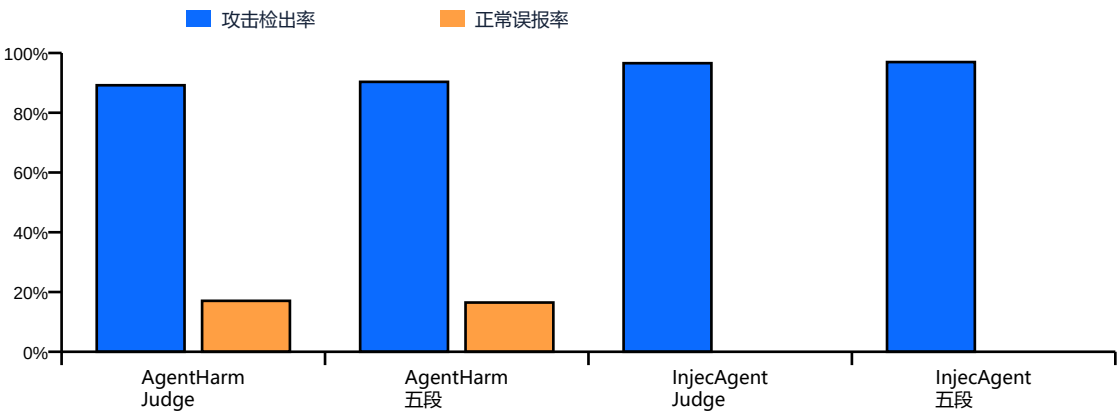
创新	技术内容	相对直接 LLM Judge 的优势
五层证据堆叠	将硬边界、能力范围、影响半径、会话漂移和处置摩擦分层	每层职责清晰，便于消融、调参和测试
状态机主导的 Drift	LLM 只提取离散标签，分值、重试惩罚和阈值由代码维护	避免模型直接打分的随机性与不可复现
意图流 + 行为流	同时关联 Prompt、模型输出、工具结果与实际调用	发现单步合法但组合危险的链式攻击
Manifest 最小权限	能力、路径、网络及影响范围显式声明	把模糊“可信 Agent”转化为可审计契约
受治理免疫学习	序列签名进入候选和影子态，人工批准后受限贡献 Drift	可以学习新攻击，但不能自行形成无限权重阻断
检测与副作用解耦	检测器输出 Signal[]，最上层统一执行阻断、确认或脱敏	支持离线评测、A/B 测试和模型替换
可验证证据链	审计记录串联前序哈希并提供完整性校验	帮助发现事后文件级篡改，明确不夸大内存防护

工程取舍

项目优先解决运行时权限、会话漂移和审计证据，不在本阶段引入 eBPF、复杂微沙箱或大规模模型训练。这样既保持本科团队可实现性，也让创新点能够通过代码、测试和演示被评委复核。

实验验证与证据边界

公开数据集用于离线 PreTool 网关重放，候选工具从未执行



数据集 / 方案	攻击样本	正常样本	检出率	正常误报率	P95 延迟
AgentHarm · DeepSeek 直接 Judge	176	176	89.20%	17.05%	1133.91 ms
AgentHarm · 五段 + 证据 + 聚焦复核	176	176	90.34%	16.48%	1251.91 ms
InjecAgent · DeepSeek 直接 Judge	1054	17	96.58%	0/17	1049.05 ms
InjecAgent · 五段 + DeepSeek 证据	1054	17	96.96%	0/17	1049.29 ms

必须同时说明的边界

- AgentHarm 参数在同一公开分片上开发，属于同分片探索性优化，不是独立泛化证明。
- InjecAgent 使用冻结配置跨数据集复测；正常对照仅 17 条，0/17 不能宣传为总体误报率为零。
- 这里报告的是网关检测/处置结果，不能与论文中的原生攻击成功率、Utility 或 Harm Score 直接横比。
- 开发 workflow 回归集合 370 条内部合成样本；推荐 Manifest 在该集合上日常干扰率为 0%，危险保护率为 70%，但不代表生产环境结论。

产品界面与审计体验

一次调查从告警进入会话，再落到工具调用与证据

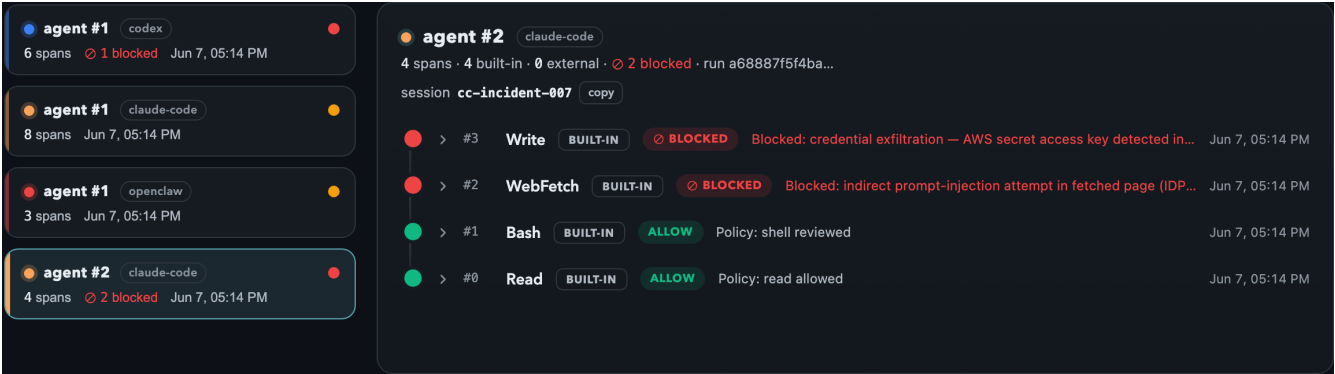


图 1 Agent Run Trace：按会话展示每次工具调用的 Allow / Block 结果及原因。截图仅展示不含历史品牌标识的运行轨迹区域。

界面模块	核心问题	用户操作
会话安全	本次会话是否发生主题偏移或权限试探？	查看 Drift 曲线、分层信号、Allow/Confirm/Block
Agent Runs	哪一步、哪个工具、哪个参数触发了策略？	按运行时与会话回放 Trace，展开证据
Manifest 管理	Agent 被允许使用哪些能力？	选择预设、设置范围、模拟变更、发布版本
即时审计	历史记录是否包含高危行为或凭据？	扫描本地会话、脱敏、导出报告
安全运营	告警背后的制度和上下文是什么？	检索证据、运行调查 Agent、人工审批提案
完整性验证	审计记录是否被删除或修改？	一键验证 SHA-256 哈希链

中英文一致性

前端提供中英文切换，核心功能、风险原因和操作提示使用统一词典；参赛演示以中文为主，保留英文术语以便国际化展示。

部署、隐私与开源治理

本地优先不等于孤立：既能离线运行，也能接入企业安全体系

维度	当前交付	企业扩展方向
部署	Windows/Linux 本地运行，轻量 Docker Demo	私有化控制平面、高可用 Worker、Kubernetes
数据	SQLite、本地日志、默认只保存脱敏预览	PostgreSQL、对象存储、组织级留存策略
身份	本地 UI Token 与敏感接口保护	SSO、RBAC、审批链与租户隔离
模型	规则和本地 Guardian 默认可用，DeepSeek 可选	企业模型网关、本地大模型、调用配额与审计
外部集成	Webhook、NDJSON、基础 SIEM 适配	Splunk、Sentinel、Datadog、OTLP 与工单系统

隐私与安全原则

- 默认本地运行，无需注册账号或上传原始 Prompt；外发仅在管理员显式配置目标后发生。
- 密钥和敏感字段在持久化前脱敏；审计预览限制长度，不保存原始载荷。
- 安全运营 Agent 使用闭集只读工具，不能获得任意 Shell，也不能直接修改执行策略。
- 高风险策略变更必须先模拟，再按提案哈希人工审批并幂等应用。

开源治理

项目采用 Apache License 2.0，保留 LICENSE、NOTICE、SECURITY、变更记录及第三方来源说明。代码同时托管于 GitHub 与 Gitee，并计划以贡献指南、Issue/PR 模板、公开 Roadmap 和安全披露流程持续建设社区。

项目可持续发展

社区版积累真实反馈，企业版围绕组织级治理与服务形成收入

版本	目标用户	核心价值	商业方式
Community / Academic	个人开发者、高校实验室、开源社区	Agent 攻防实验、单机治理、Benchmark 与基础插件	Apache-2.0 免费开源，积累适配器和真实反馈
Team	初创团队与小型研发组织	团队策略、共享 Manifest、审计留存和基础支持	规划定价 499 美元/年；属于商业计划，不是已发生收入
Business / Enterprise	中大型企业、自研 Agent 平台和安全团队	SSO/RBAC、集中策略、私有化部署、合规审计与 SLA	年度订阅 + 私有化授权 + 专业实施与定制服务

阶段	目标	可验收结果
参赛交付	稳定安装、五分钟演示、公开复现	版本化仓库、PDF、演示视频、Benchmark 脚本
社区验证	高校实验室与开发团队试用	真实 Issue/PR、匿名开发轨迹、误报标注集
团队产品	策略共享与小规模集中管理	组织空间、设备同步、审计保留、支持服务
企业产品	私有化治理控制面	SSO/RBAC、审批链、高可用、租户隔离、SIEM/SOC 集成

长期壁垒

产品壁垒将来自三类积累：跨 Agent 的运行时适配与权限语义、真实开发工作流中的低误报策略数据、以及可追溯的 Manifest/审计治理标准。项目不以单一模型能力作为护城河。

总结与提交信息

让 Agent 的能力增长建立在可控、可解释、可审计的基础上

AI Aegis 面向正在快速普及的 AI 编程 Agent 和企业自研 Agent，提供从执行前安全决策到事后审计调查的完整闭环。项目以五段式管线为核心，将确定性规则、语义证据、会话状态机和分级处置解耦，避免把安全完全托付给随机的大模型判断。

可运行	可测试	可解释	可演进
插件、后台与本地部署形成完整产品闭环	公开基准、内部回归、JSON/CSV/Markdown 结果	信号、分数、策略版本与处置理由可追溯	社区版与企业治理控制面路线清晰

提交信息

项目名称	AI Aegis（灵盾）：面向企业自研 Agent 的开源运行时安全治理与可观测平台
参赛方向	开源 AI 工具赛道 - AI 编程、调试与可观测工具 - 自主选题
项目负责人	万翔浩
代码仓库	GitHub: https://github.com/Goodevenin9/ai-aegis Gitee: https://gitee.com/wan-xianghao/ai-aegis
开源协议	Apache License 2.0（上游来源与变更说明见 NOTICE）

声明：本文档所列“当前交付”均以仓库代码和归档报告为依据；规划能力、计划定价与企业产品化方向均明确标注，不作为已完成或已产生收入的事实陈述。

附

证据索引与复现入口

便于评委从结论回到代码、配置与原始报告

证据类型	仓库路径 / 入口	说明
五段管线设计	docs/FIVE_STAGE_PRETOOL_PIPELINE.md	各层输入、信号、阈值与决策原则
交付验收	docs/COMPETITION_ACCEPTANCE.md	功能边界、测试、部署和未完成项
AgentHarm 机器报告	reports/agentharm-five-stage-optimized-final-20260917/	JSON、CSV、Markdown 与实现/配置哈希
InjecAgent 冻结复测	reports/injecagent-frozen-five-stage-20260917/	跨数据集复测及 Wilson 区间说明
开发工作流回归	reports/developer-workflows-v1-20260918/	370 条内部工程回归样本和 Manifest 对照
安装与使用	docs/GETTING_STARTED.md · docs/INSTALLATION.md	本地安装、启动与接入流程
API 与 SDK	docs/API_SPECIFICATION.md · docs/SDK_USAGE.md	接口契约和 Agent 集成
开源合规	LICENSE · NOTICE · SECURITY.md	协议、来源、商标与安全披露

Benchmark 复现原则

- 固定数据版本、代码提交、配置哈希、模型名称和证据 Schema。
- 候选工具只进行离线重放，禁止真实执行危险命令。
- 同时报告攻击检出率、正常误报率、确认率、硬阻断率、Precision、F1 与延迟。
- 开发集、验证集和测试集隔离；免疫学习不得使用测试真值生成抗体。
- 任何对外数字必须能回溯到机器可读 JSON/CSV 和明确口径。

赛事资料来源

2026 上海开源软件应用创新大赛官网：<https://www.oschina.net/os2026/>。本项目按“开源 AI 工具赛道 - AI 编程、调试与可观测工具”准备材料。